FICTIONAL PROTOTYPE · Fictional organisation · Test-fixture figures, not an approved score · Not a certified paid report

MK FRAUD INSIGHTS

ESSENTIAL FRAUD READINESS REPORT

58 of the 106 fraud schemes that apply have a control reported as a gap, most of them in digital channels, procurement and people.

55.5 / 100 **DEVELOPING**

Calculated figure, a test fixture. Not an approved score or readiness conclusion.

PREPARED FOR

Fictional Retail Group (mixed controls)

Assessment reference · FX-P3

Assessment date · 12 November 2026

CONFIDENTIAL · PREPARED FOR THE MANAGEMENT OF FICTIONAL RETAIL GROUP (MIXED CONTROLS)

WHAT DOES THE ASSESSMENT SHOW?

Fraud readiness at a glance

55.5	Developing	10	92.50	18.60
CALCULATED FIGURE (TEST FIXTURE)	MATURITY BAND	DOMAINS ASSESSED	STRONGEST DOMAIN	WEAKEST DOMAIN
			Finance, banking & financial reporting	**Digital, cyber-enabled & identity fraud**

106 fraud schemes apply to the organisation. For 47, every control asked about was reported in place, and for 1 the control that stops the scheme is reported in place while a further defence is weaker. 58 have a control reported as a gap, 22 of them in tier 1, the schemes the draft method confirms in its core stage. The core stage is complete; all 106 schemes asked about can be analysed in full from the answers given. The calculated figure above is a test fixture from a research simulation, not an approved score or readiness conclusion.

Domain readiness profile



Ordered weakest first. Calculated figures from a research simulation (test fixtures), not approved scores.

WHY DOES THE POSITION LOOK LIKE THIS?

What the answers show

PATTERN	ASSESSMENT SIGNALS	WHY IT MATTERS
Digital, cyber-enabled and identity fraud: 14 schemes with a control reported as a gap	Multi-factor on all email **Not in place** Email never enough on its own **Not in place** Verification for calls, voice notes and video **Partly in place**	Most business email compromise starts with an account that has no multi-factor authentication. The same area also has open: a payment instruction received by email is acted on and a cloned voice or video instruction is obeyed.
Third parties and supply chain: 12 schemes with a control reported as a gap	New supplier process **Partly in place** Change confirmed with supplier **Partly in place** Familiar caller still verified **Not in place**	Fictitious suppliers enter through onboarding that can be skipped. The same area also has open: supplier payments are diverted through changed bank details and a supplier is set up with an account it does not own.
People, payroll and insider risk: 11 schemes with a control reported as a gap	Bank changes confirmed with employee **Not in place** Payroll reviewed by another person **Partly in place** Leavers removed before next run **Partly in place**	Salary redirection through fake bank change requests is common and fast. The same area also has open: ghost employees are paid and leavers stay on the payroll.
1 scheme: control in place, a further defence weaker	Training on joining **Partly in place**	Each weaker practice is a separate defence against the same scheme. The control that stops the scheme stands as reported; the practices are listed in the register.

THE PATTERN THAT MATTERS

In the one scheme where a control was reported fully in place and a practice of the same scheme weaker, the method's wording shows the practice is a separate defence, so the reported control stands as given. Separately, 5 of 32 controls that can be cross-checked were asked one further question: 5 consistent, 0 conflicting and 0 with a separate practice reported weaker. These compare the organisation's own answers; they are not tests of operation and change no figure.

WHERE DOES FRAUD EXPOSURE MATTER MOST?

Fraud schemes the answers point to

#	FRAUD SCHEME	ASSESSMENT BASIS	POTENTIAL CONSEQUENCE	INTERRUPTION POINT	WHY IT IS LISTED
1	**An email account is taken over** A mailbox without strong sign-in is used to send or intercept payment instructions.	Multi-factor on all email **Not in place**	Most business email compromise starts with an account that has no multi-factor authentication.	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.	**Gap, tier 1** Its control is reported as not in place.
2	**A fictitious supplier is created and paid** An insider or outsider adds a supplier that does not exist and invoices it.	New supplier process **Partly in place**	Fictitious suppliers enter through onboarding that can be skipped.	Every new supplier goes through a defined process, with set checks and an approval, before it can be paid.	**Gap, tier 1** Its control is reported as partly in place.
3	**Salaries are redirected through a fake bank change** A request that appears to come from an employee changes where their salary is paid.	Bank changes confirmed with employee **Not in place**	Salary redirection through fake bank change requests is common and fast.	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.	**Gap, tier 1** Its control is reported as not in place.
4	**Refunds are stolen** One person raises and approves refunds or credit notes to themselves or accomplices.	Refunds approved independently **Partly in place**	Refunds processed and approved by one person are a classic way to steal.	Every refund and credit note is approved by someone other than the person who processes it.	**Gap, tier 1** Its control is reported as partly in place.
5	**Cash takings are stolen** Takings are under-recorded or removed before banking.	Daily reconciliation **Partly in place**	Daily reconciliation of takings is the main control over cash theft.	Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated.	**Gap, tier 1** Its control is reported as partly in place.

Listed with answers to resolve first, then one scheme with a control reported as a gap from each area, areas with the most such schemes first. This is a presentation order: MK has not approved a method for rating fraud risks, and every scheme is in the register.

HOW COULD THAT EXPOSURE MATERIALISE?

How the schemes would work here

An email account is taken over

A mailbox without strong sign-in is used to send or intercept payment instructions › Multi-factor on all email not in place › Takeover of staff accounts

A mailbox without strong sign-in is used to send or intercept payment instructions. Most business email compromise starts with an account that has no multi-factor authentication. Here, email accounts are protected by passwords only.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.

Warning signs: Takeover of staff accounts · Business email compromise and payment redirection

A fictitious supplier is created and paid

An insider or outsider adds a supplier that does not exist and invoices it › New supplier process partly in place › Fictitious or shell suppliers

An insider or outsider adds a supplier that does not exist and invoices it. Fictitious suppliers enter through onboarding that can be skipped. Here, checks happen only when someone thinks to do them.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. Every new supplier goes through a defined process, with set checks and an approval, before it can be paid.

Warning signs: Fictitious or shell suppliers

Salaries are redirected through a fake bank change

A request that appears to come from an employee changes where their salary is paid › Bank changes confirmed with employee not in place › Salary redirection through changed bank details

A request that appears to come from an employee changes where their salary is paid. Salary redirection through fake bank change requests is common and fast. Here, bank detail changes are made as requested.

Interrupted by: A check of new cases by hand against the method's standard, until the control operates. Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.

Warning signs: Salary redirection through changed bank details

These are plausible schemes for an organisation with the controls it reported. They are not allegations that these events have occurred.

WHAT DOES MANAGEMENT NEED TO CHANGE?

What management should address first

#	MANAGEMENT OUTCOME	WHY NOW	ACCOUNTABLE	WHAT GOOD LOOKS LIKE
1	**Name an owner for each area and decide the order of work**	The draft method does not rank fraud risks by likelihood or impact, so this report does not either. Which of the 58 open schemes to address first is management's decision, informed by its own volumes and values.	Chief executive	Each area with open schemes has one accountable executive, and the order of work is recorded with the reason for each choice.
2	**Put in place: multi-factor on all email**	Stops the scheme where an email account is taken over. Its control is reported as not in place.	IT lead	Multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
3	**Put in place: new supplier process**	Stops the scheme where a fictitious supplier is created and paid. Its control is reported as partly in place.	Procurement lead	Every new supplier goes through a defined process, with set checks and an approval, before it can be paid.
4	**Put in place: bank changes confirmed with employee**	Stops the scheme where salaries are redirected through a fake bank change. Its control is reported as not in place.	HR and payroll lead	Every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.
5	**Put in place: refunds approved independently**	Stops the scheme where refunds are stolen. Its control is reported as partly in place.	Commercial and customer lead	Every refund and credit note is approved by someone other than the person who processes it.
6	**Put in place: daily reconciliation**	Stops the scheme where cash takings are stolen. Its control is reported as partly in place.	Operations lead	Takings at every cash point are reconciled to sales records daily, and every shortage and surplus is investigated.

WHAT SHOULD HAPPEN IN THE FIRST 90 DAYS?

The first 90 days

The windows order the work by what must be known and decided before controls are designed. They set no deadline from a scheme's tier or the answers given; dates are management's decision.

30 days: Establish the facts and owners

0–30 DAYS

Answers that conflict are resolved, outstanding answers are obtained and each area with open schemes has an accountable executive.

Name the accountable executive for each area with open schemes, and decide which schemes to address this cycle. — Chief executive

Named executives and a recorded order of work.

Complete when: Every open scheme is selected, deferred with a reason or accepted at the right level.

60 days: Design the controls, prerequisites first

31–60 DAYS

Approved designs exist for the schemes management selected, with the controls others rely on designed first.

Approve the target design for each selected scheme, using the standards in this report. — Each accountable executive

Approved designs, each with an owner and the records it will keep.

Complete when: Each selected control has an approved design and a named owner.

90 days: Start operating and report

61–90 DAYS

The first designed controls operate for a full cycle and the oversight body sees the status of every scheme.

Start operating the approved designs and review the first full cycle against the success measures. — Each process owner

A first-cycle review for each control, with exceptions and their resolution.

Complete when: Each control has met its success measure for one cycle, or has a recorded correction.

Report the status of each open and unresolved scheme to the board or its audit committee. — Chief executive

A one-page status per scheme: owner, controls in place, controls outstanding, next step.

Complete when: The status is received and minuted.

HOW WILL MANAGEMENT KNOW WHETHER READINESS IS IMPROVING?

What to check at the 90-day point

MEASURE	POSITION TODAY	90-DAY EXPECTATION
Multi-factor on all email	Email accounts are protected by passwords only.	Records for the period show that multi-factor authentication is required for every email account, including executives' and shared mailboxes, with no exceptions.
New supplier process	Checks happen only when someone thinks to do them.	Records for the period show that every new supplier goes through a defined process, with set checks and an approval, before it can be paid.
Bank changes confirmed with employee	Bank detail changes are made as requested.	Records for the period show that every change is confirmed through a channel the organisation starts, such as a call to a number on file or in person, before it takes effect.
Open schemes with a named owner and a decision	None recorded in the assessment (58 open).	Each selected, deferred with a reason or accepted at the right level.

Management conclusion

Fictional Retail Group (mixed controls)'s answers show 48 schemes with the controls that stop them reported in place and 58 with a control reported as a gap, most of them in digital channels, procurement and people. The draft method does not yet rank fraud risks, so the order of the remaining work is management's decision; the supporting register lists every scheme, control and record behind this report.

This report is based on the organisation's own answers to the MK Fraud Readiness review, given by the respondent and the accountable functions named in it, and read against the draft review method, which MK has not yet approved. MK has not independently tested whether controls operate in practice, and no evidence was reviewed; evidence review is a separate Advisory service. The records named in this report are records management should maintain; MK has not requested or examined them. TEST FIXTURE: hypothetical research value (scoring-frame simulation, Option A, midpoint, equal areas, no caps). Not an approved score, band or rating.